

SOC-Copilot

AI-Assisted Triage for Authentication Anomalies

Course: **Introduction to AI for Cybersecurity**
Academic year 2025/26 - Semester B (Spring)

Lecturers: **Dr. A. Kojukhov & V. Nefedov**
Students: **Stav Hefetz & Bar Koldanov**

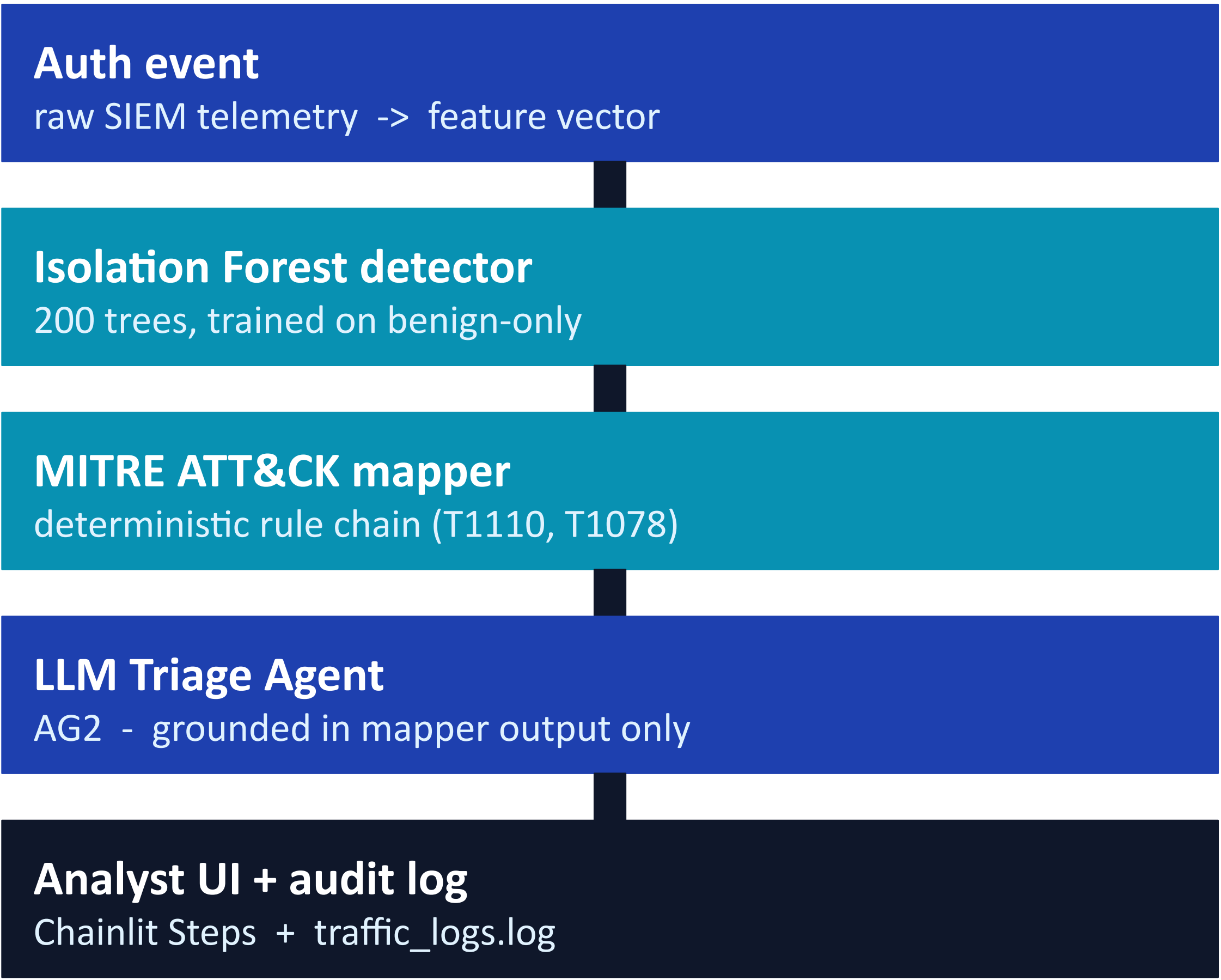
1. Introduction

The problem. Tier-1 SOC analysts face two compounding failures: alert fatigue (thousands of events per day, most are noise) and a context gap (raw telemetry is not yet mapped to MITRE ATT&CK techniques or recommended responses). The result is genuine intrusions dismissed as noise, a documented failure mode in major breaches.

Rationale. Combine three components, each with a sharp job: an unsupervised anomaly detector for cheap detection, a deterministic rule-based mapper for auditable MITRE attribution, and a constrained LLM agent for analyst-friendly explanation. The LLM never sees raw threat-intel data, so it cannot invent technique IDs.

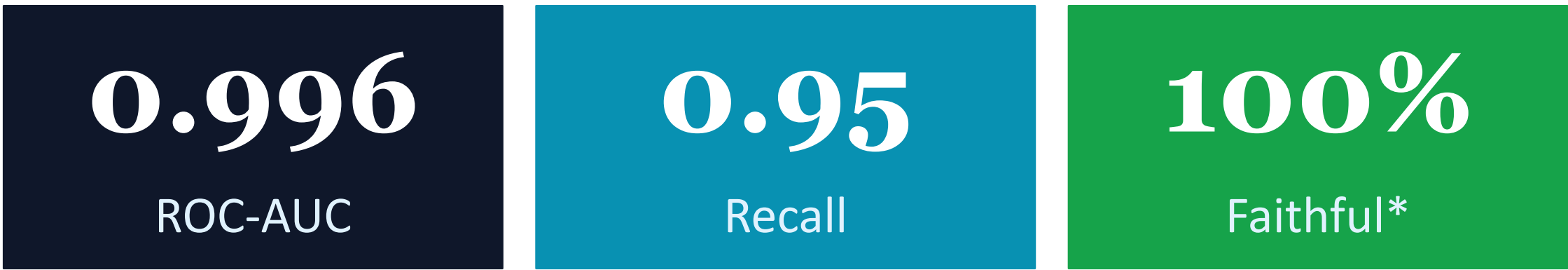
Goals & objectives. (1) Train an Isolation Forest on benign-only authentication events; (2) build a rule-based MITRE mapper covering T1110.001, T1110.003 and T1078; (3) integrate an AG2 LLM agent that summarises every alert in plain English, grounded

2. Methodology & Architecture



The LLM is constrained by architecture, not just by prompt: it never sees raw threat-intel data, so it cannot invent technique

3. Results & Evaluation



Per-technique recall (test set, n=2,500)

MITRE Technique	n	Recall
T1110.001 Brute Force	41	100 %
T1110.003 Password Spraying	23	100 %
T1078 Valid Accounts	11	64 %

Adversarial scenarios. Burst brute force 100 % - spraying 100 % - valid accounts 65 % - evasive (attacker mimics benign) 0 %. The 0 % is the honest limit of per-event detection; cross-event correlation is needed for that case (see Discussions).

* LLM faithfulness: % of explanations whose claims all trace to mapper output, manual review n=20.

4. Conclusions

Goals achieved. All five objectives in §1 were met: trained Isolation Forest (ROC-AUC 0.996); deterministic mapper covering three MITRE techniques; AG2 triage agent grounded in mapper output (100 % faithfulness on 20-sample manual review); Chainlit MVP with JSONL audit log; quantitative evaluation on held-out data and four scripted scenarios.

Compared to targets. Target was to **approach** a supervised baseline without using labels at training. The unsupervised model reaches recall 0.95 while training on benign rows only - matching the project pitch. The model is strongest where the signal is loud (T1110 variants, 100 % recall) and weakest where the signal is genuinely sparse (T1078, 64 %). This honest gradient is a **result**, not a defect - it tells the SOC operator exactly where to deploy compensating controls.

5. Discussions & Future Work

Next iterations.

- 1. Cross-event correlation.** The 0 % detection on the evasive T1078 scenario is the limit of per-event reasoning. Adding impossible-travel and first-time-from-this-IP-ever signals defeats the Volt-Typhoon SOHO-router playbook.
- 2. Live data feed.** Replace the synthetic generator with a 30-day rolling window of the customer's own auth logs and add drift monitoring on feature distributions.
- 3. Mapper expansion.** Cover the top-20 enterprise MITRE techniques; route low-confidence cases to a retrieval-augmented LLM call grounded in STIX.
- 4. Incident grouping.** Aggregate correlated events keyed on source IP / user over a sliding window into single incidents.

